

«File System Forensics Lab »

Lab #1

L'utilisation de l'informatique légale dans le cadre de l'analyse de fichiers est généralement utilisée pour récupérer et analyser des données issues de périphériques de stockage. Cela consiste habituellement à effectuer une copie du périphérique physique en question, à en vérifier l'intégrité et à analyser la copie ainsi obtenue avec différents outils forensiques.

Dans ce premier TP, les copies des périphériques physiques ont déjà été faites et vous vous concentrerez sur l'analyse des « dumps » résultants. Pour ce faire, différents types d'outils seront utilisés : des outils UNIX de base tels que *dd*, *grep*, *xxd* ou *hexeditor* et des outils plus orientés « forensics » issus du « Sleuthkit », l'un des toolkits Open Source les plus utilisés.

Installation préliminaire de l'environnement

Dans cette partie, vous allez déployer l'environnement Docker de Lab, environnement qui sera utilisé pour les 4 premiers Labs de l'analyse forensique des systèmes de fichiers.

- Connectez-vous au cours Learner Lab sur AWS Academy et démarrez le Learner Lab dans la partie Modules
- Connectez-vous à votre instance : **UQAC Lab 1**
- Récupérez l'archive dont l'URL est fournie sur Moodle sous le nom « forensics_labs.tgz » en utilisant la commande : ***wget -O forensics_labs.tgz "URL_donnée_sur_Moodle"***

Le checksum sha-256 de l'archive est :

f44f6dc103617fc2066d01bd91c4ac4e75f44c1e34f8711f31e254d50f91c9e5

- Décompressez l'archive et allez dans le répertoire : *forensics_labs*
 - Créez l'image docker qui sera utilisée dans ces Labs en tapant : ***./build.image.sh***
- Cette commande va créer une nouvelle image Docker appelée : *debian-forensics* qui est basée sur l'image officielle Debian.

Comment pouvez-vous vérifier la présence de ces images sur votre instance ?

- Exécutez le conteneur de TP en tapant : ***./run.forensics.sh***
- Vous serez automatiquement connecté à un shell du conteneur en mode interactif. Le paquetage *tmux* est installé dans le conteneur. N'hésitez pas à l'exécuter (dans le conteneur) afin d'avoir une meilleure expérience utilisateur.

Le répertoire *case* de votre instance est également automatiquement monté dans votre conteneur. Il est disponible à partir du répertoire */root/case* au sein du conteneur. Tout ce que vous créerez dans ce répertoire sera donc persistant et disponible dans l'instance AWS initiale. Tout fichier créé ailleurs sera éphémère et détruit si le conteneur est détruit.

Les images disques utilisées dans ce TP et les prochains sont situés dans ce répertoire.

- Votre environnement de TP est maintenant opérationnel

Analyse de base d'un système de partitions

Dans cette première partie, vous allez analyser un système de partitions de type MBR.

Sur un disque au format MBR, comme vu en cours, la table de partitions peut contenir jusque 4 entrées, appelées partitions primaires.

Les tables ci-dessous donnent (source : https://wiki.osdev.org/Partition_Table) :

- Les adresses de chaque entrée de cette table, adresses à partir du début du disque,
- La signification des différents bits de chaque entrée.

Partition number	Offset
Partition 1	0x01BE (446)
Partition 2	0x01CE (462)
Partition 3	0x01DE (478)
Partition 4	0x01EE (494)

Element (offset)	Size	Description
0	byte	Boot indicator bit flag: 0 = no, 0x80 = bootable (or "active")
1	byte	Starting head
2	6 bits	Starting sector (Bits 6-7 are the upper two bits for the Starting Cylinder field.)
3	10 bits	Starting Cylinder
4	byte	System ID
5	byte	Ending Head
6	6 bits	Ending Sector (Bits 6-7 are the upper two bits for the ending cylinder field)
7	10 bits	Ending Cylinder
8	uint32_t	Relative Sector (to start of partition -- also equals the partition's starting LBA value)
12	uint32_t	Total Sectors in partition

Un dump du disque à analyser a été fait avec l'outil UNIX *dd*. Il est disponible sous le nom ***multiple1.dd***.

Compte tenu du type de support utilisé, les valeurs relatives aux informations HCS n'ont pas de significations particulières et seules les valeurs des octets 9 à 16 seront utilisés pour localiser les partitions sur le disque.

Utilisez l'outil *xxd* pour décoder chaque entrée de la table de partitions.

Conseil : utilisez l'option *-s* de *xxd* pour vous déplacer. Vous pouvez consulter la « man page » de *xxd* pour vérifier la syntaxe.

À partir de cette analyse, vous devriez être capable de remplir le tableau suivant :

Élément	0 (bootable flag)	4 (System ID)	8 (RelSec)	12 (PartLength)
Partition 1	Hex : 0	Hex : Insérer du texte à l'endroit indiqué	Hex : 000800000	Hex :
	Dec : 00	Type :	Dec : 00	Dec : 00
				Taille :
Partition 2	Hex :	Hex :	Hex :	Hex :
	Dec :	Type :	Dec :	Dec :
				Taille :
Partition 3	Hex :	Hex :	Hex :	Hex :
	Dec :	Type :	Dec :	Dec :
				Taille :
Partition 4	Hex :	Hex :	Hex :	Hex :
	Dec :	Type :	Dec :	Dec :
				Taille :

Note : Vous pouvez retrouver les types standards de systèmes de fichiers dans les planches de cours.

Utilisez les informations précédentes pour extraire chaque partition en utilisant l'outil UNIX *dd*.

Afin de valider vos résultats, la « shasum 256 » de chaque partition obtenue doit être la suivante :

- 86f095177d3cfbc5f40f9b50b88bf415d657a1a701e6713b0aeab31d41d26f29 part1.dd
- 44dec3ae5b93c4fa3e1f5632a6aeb9fe1796bf4591a2ebc9bf1651c415fa5d2 part2.dd
- d57c509067919b9def3d5f9168eb4421cbb8314d29cde32fc5e346a6ea3574ff part3.dd
- 9659869705a16adadca59faf3f732ac41a170384decc1e97cedb4ab09f5d5be9 part4.dd

Créez les répertoires nécessaires dans votre espace de travail et montez en lecture seule, chaque partition « utilisable » sur votre système UNIX en utilisant la commande **mount** avec l'option **-o ro**.

Parcourez les différentes partitions montées et récupérez les informations contenues dans les fichiers FLAG qui s'y trouvent.

Utilisez les informations ainsi obtenues pour décoder le message présent.

La shasum 256 du message décodé devrait être :

92105af28b8e0227b7ae4ed4405cc0c7fbbd7a91f281a67660933e27e1ec0522

Dé-associez (démontez) les différentes partitions montées puis, montez-les en mode rw (c'est le mode

par défaut lors d'un montage). Calculez-en les shasum 256 et comparez la valeur obtenue aux originaux. Conclusion par rapport à ce qui a été vu en cours. Quelle pourraient être les impacts dans un cas réel ? Quelles précautions pourriez-vous prendre pour éviter ce problème ?